

Project 02
Incident Response
Simulation

SADIKI MULANGA

Scenario

An employee receives a phishing email pretending to be from the company's IT department. The employee clicks the link and enters their company username and password on a fake login page. The attacker obtains the credentials and attempts to access the company's systems.

Detection

The security team detected unusual activity on an employee's account after monitoring systems recorded multiple login attempts from an unfamiliar IP address and location.

The login activity was considered suspicious because the IP address and location were not consistent with the employee's normal login behaviour. The security team investigated the activity and discovered that the employee had recently received a suspicious phishing email.

Further investigation showed that the employee had clicked a link in the email and entered their company credentials on a fraudulent login page. This indicated that the employee's credentials may have been compromised.

Initial assessment:

- Incident type: Phishing / Credential Compromise
- Affected asset: Employee account
- Indicators: Unusual login attempts and unfamiliar IP address
- Potential impact: Unauthorized access to company systems
- Severity: Medium–High

Containment

The security team immediately disabled the compromised employee account to prevent the attacker from continuing to access company systems.

The employee's password was reset, and all active login sessions were revoked. The security team also blocked the suspicious IP address associated with the unauthorized login attempts.

The phishing email was removed from the employee's mailbox and other affected mailboxes to prevent additional employees from clicking the malicious link.

The security team continued monitoring the affected account and related systems for any further suspicious activity.

Containment actions:

- Disabled the compromised account
- Reset the employee's password
- Revoked active login sessions
- Blocked the suspicious IP address
- Removed the phishing email
- Increased monitoring for further suspicious activity

Eradication

The security team investigated the compromised account and confirmed that the employee's credentials had been captured through a phishing website.

The fraudulent website and phishing link were identified and reported for blocking. Security tools were updated to prevent similar malicious links from being accessed by employees.

The employee's device was checked for signs of malware or other unauthorized software. No further malicious activity was identified.

The security team also reviewed the employee's account permissions and login activity to determine whether the attacker had accessed any additional company resources.

Eradication actions:

- Identified the phishing website and malicious link
- Blocked the malicious website and link
- Checked the employee's device for malware
- Reviewed account activity and permissions
- Confirmed that no further unauthorized access was detected
- Updated security controls to reduce the risk of another phishing attempt

Recovery

After the threat was removed, the security team restored the employee's access to company systems.

The employee was required to create a new secure password and enable multi-factor authentication (MFA) to provide an additional layer of protection.

The security team monitored the employee's account and systems for further suspicious activity before fully returning the account to normal operation.

The employee was also informed about the phishing attack and reminded how to identify and report suspicious emails in the future.

Recovery actions:

- Restored the employee's account access
- Created a new secure password
- Enabled multi-factor authentication (MFA)
- Monitored the account for suspicious activity
- Confirmed that systems were operating normally
- Reminded the employee about phishing awareness

Lessons Learned

The incident demonstrated the importance of employee awareness, strong authentication, and continuous security monitoring.

The employee was able to identify and report the phishing incident, but the organization recognized that additional security measures were necessary to reduce the risk of similar attacks.

The organization decided to provide additional phishing-awareness training to employees and conduct simulated phishing exercises to improve employee awareness.

Multi-factor authentication (MFA) would also be required for company accounts to provide additional protection if passwords are compromised.

The security team would continue monitoring login activity and improve email security controls to detect and block suspicious messages and links.

Lessons learned:

- Provide regular phishing-awareness training
- Conduct simulated phishing exercises
- Require MFA for company accounts
- Improve email filtering and security controls
- Monitor unusual login activity
- Encourage employees to report suspicious emails immediately
- Regularly review and improve the incident-response process